

UNIT 3: MALICIOUS WEB AND DOCUMENT FILES

Dhanashree Kulkarni

Index



- ❑ Interacting with Malicious Websites to Assess the Nature of Their Threats;
- ❑ De-obfuscating Malicious JavaScript Using Debuggers and Interpreters;
- ❑ Analyzing Suspicious PDF Files;
- ❑ Examining Malicious Microsoft Office Documents, Including Files with Macros;
- ❑ Analyzing Malicious RTF Document Files

- 
- The web is a dangerous place, where criminals constantly seek to **mislead ordinary users**.
 - One of the most common cybercrime strategies is setting up malicious websites which **fool visitors into providing information or making dangerous decisions**.
 - As of July 2022, Google reported **delivering 5 million malicious site warnings every day** and recorded around **2 million phishing websites in early 2020**.
 - Both phishing and malware remain worldwide problems with huge potential security risks.

What is a malicious website?

- As the name suggests, malicious sites intend to cause harm.
- They are not eCommerce stores, financial providers, or web applications that deliver essential services securely.
- Instead, they seek to steal valuable data or inject malicious software onto visitor devices.
- **The ability to copy familiar, reputable sites makes malicious websites so dangerous.** For instance, Amazon replicas are common, and PayPal scams are increasingly popular amongst phishers.
- Malicious sites are often incredibly **similar to legitimate versions.**
- However, they **rarely appear in mainstream search results.** Instead, **victims encounter them via emails and pop-ups created purely to deceive.**

How do malicious websites work?

- While they always seek to betray, malicious websites come in various forms. There are two different types: **phishing sites and malware sites.**
- Cybercriminals engineer phishing sites to tempt visitors to enter sensitive information. **Victims could enter information via standard online forms, requesting documents, or signing up for mailing lists.**
- Phishing sites generally **seek high-value data like credit card numbers, login credentials, and home addresses.**
- That explains why replica-popular payment portals like eBay are common imposters.

How do malicious websites work? Continue...

- ❑ Malware-based malicious websites exist solely to implant harmful software on target devices. This malware can gather data and send it to hackers, interfere with the operation of systems, or carry out unwanted tasks like crypto-mining. These sites have a range of approaches, including following three major points:
 - ❑ Drive-by downloads - Criminals can implant malware onto devices without needing to fool people into providing information. So-called 'drive-by downloads' can deliver malicious code without visitors being aware. There is no prompt to download software and no sign that the target device is now infected with malware. Corrupted javascript or plugins are all that criminals require.

How do malicious websites work? Continue...

- Malicious files - Many phishers continue to rely on .exe files sent via email attachments or as pop-up downloads on fake websites. These files usually refer to apps like antivirus checkers or media players. So targets generally have a reason to download them. Video codec downloads are another common vector. When video fans click the links, they automatically install malware that unpacks and starts to run.
- Malvertising – Malvertising uses corrupted pop-up ads to send malware to unsuspecting targets. These ads could be part of legitimate networks and appear normal. But when clicked, they trigger malware downloads or send users to other malicious websites.

Web-based exploits

- Web-based exploits aim to compromise users when they browse, or attempt to browse, to specific webpages.
- They function by compromising or impersonating a website that victims wish to visit, compromising the victim themselves, or exploiting vulnerabilities in the systems that direct users to the correct webpage

Drive-by exploit

- A drive-by exploit refers to malicious code that a cyber threat actor has placed on a website without the website host's knowledge; the malicious code attempts to compromise the devices of any user who visits the website.
- Examples?

Formjacking

- Formjacking is when cybercriminals inject malicious code into a webpage form, such as a payment page, to compromise it and steal credit card details and other information that is entered by users on these pages.
- Examples?

Pharming

- Pharming is a technique used to redirect traffic from a legitimate website to a malicious one. This deception can be achieved by modifying the user's system settings or by exploiting vulnerabilities in the domain name system (DNS) server software, which is responsible for resolving URLs into IP addresses.
- Contrary to typo-squatting (see below), where a user mistypes a website address and is redirected to an illegitimate website, pharming can redirect a user who properly types the URL. At a quick glance, the illegitimate website may appear to be the legitimate website and can be used to deliver malware and acquire personally identifiable or other sensitive information.

Typo-squatting

- Typo-squatting is a technique by which a threat actor registers domain names that have very similar spelling to and can be easily confused with a legitimate domain address.
- Typo-squatting is also known as URL hijacking and enables a threat actor to redirect a user who incorrectly typed a website address to an alternative look-alike domain under the actor's control.
- The new domain can then deliver malware and acquire personally identifiable or other sensitive information. Luring a victim to a hijacked URL can also be achieved through phishing techniques.

Watering hole

- A watering hole attack is a targeted attack designed to compromise users within a specific industry or group of users by infecting websites they typically visit and luring them to a malicious site.
- The end goal is to infect the user's computer with malware and gain access to the organizations network..

Hybrid

- There are also hybrid attacks that hijack legitimate sites and make them work for hackers. For instance, attackers could implant malicious redirects on an otherwise normal web page that funnel visitors to malicious content.
- Web applications are also vulnerable to cross-site scripting or SQL injection attacks. What seems to be a perfectly normal web portal can hide dangerous secrets.

Examples of malicious websites

- What does a malicious website look like? Unfortunately, the answer is usually: almost the same as the non-malicious original.
- Cybercriminals can easily recreate the look and layout of payment portals or newspaper sites, with few clues about their illegitimate nature.
- For example,
 - ▣ the phishing network BAHAMUT runs a highly sophisticated network of fake news websites. Taking over defunct news sites like Techsprouts, BAHAMUT created a complex web of contributors, social media accounts, and content. It used numerous zero-day exploits to deliver malware and targeted high-value individuals across South Asia and the Middle East.
 - ▣ BAHAMUT's targets saw informative emails or social media posts tailored to their interests. Suspecting nothing, they often followed links to articles or even interacted with fake experts.

Examples of malicious websites

- Other attackers are less subtle, targeting the mass of eCommerce users via well-known online brands. Recent examples include:
 - ▣ Fake PayPal sites inform users their accounts have been limited and ask them for personal information.
 - ▣ Every Prime Day, thousands of fake Amazons appear. Some cover consumer goods, while others provide “solutions” to Prime Video streaming problems that require extensive personal data.
 - ▣ Phishers have created fake eBay websites linked to emails requesting “credit card updates” or messages from imaginary members.
 - ▣ Government services can also fall victim. In the UK, the tax authorities warn about misleading websites offering fake Covid-19 tax refunds but are actually infected with malware. Wells Fargo points out that the problem is just as engrained in the USA, especially during tax filing periods.
- In all cases, attackers create websites that look very similar to the real thing. Very similar, but not exactly the same. As we’ll see there are some warning signs to look for that betray fake websites. But at first glance, most of these sites look legitimate.

How to identify a malicious website

- ❑ Malicious websites tend to have certain features in common. For instance, they might include:
 - ❑ Multiple misspellings or other textual errors that would not be common in branded or official content.
 - ❑ URLs featuring HTTP instead of HTTPS. The “S” tells you that the site has an SSL certificate and uses TLS encryption to boost data security. SSL certification radically reduces the risk posed by man-in-the-middle data theft attacks.
 - ❑ Unusual requests to download apps are a big red flag. Many malicious websites rely on a small number of users clicking on malware downloads, which pop up automatically.

□ Examples Continued..

- ▣ Fake prizes. You've probably seen these sites around the web. Any site promising a prize to the five millionth visitor is probably fake.
- ▣ Suspicious security alerts. What better way to reach wary visitors than offering a security solution? Many sites promise virus and malware protection via one-click downloads. Some also inform you that your system is out of date. In all cases, if you haven't requested assistance, it's probably not intended to help you.
- ▣ Overly generous deals that have not been advertised on the parent site or feel out of step with the brand's standard offerings.
- ▣ Slightly incorrect domain names. Scam websites tend to mimic parent sites but usually with minor differences. For instance, Amazon could become Amazon1 in the domain name.
- ▣ Thin contact and background information. Imposter sites will generally offer very little information about the company involved. Contact details will probably be false if they exist.

What happens if I visit a Malicious Website?

- There will usually be few consequences when visiting a malicious site. Security teams can neutralize many malware infections via antivirus software. And your data should remain safe if you remember to take care when entering personal information.
- However, this isn't always the case, and visiting these sites can have very damaging results:
 - ▣ Security weaknesses – If the site implants a drive-by download, it could immediately install malware and start gathering and relaying sensitive data about your activity and security vulnerabilities, potentially leading to corporate data breaches.
 - ▣ Damage from malicious code – Javascript infections can install automatically as soon as you use contaminated sites, leading to cascading redirects, damage to your files, and potentially catastrophic collapse.
 - ▣ Spreading malvertising – In other cases, clicking on malicious advertising causes problems for other web users. These ads propagate every time users click them. Copies spread across the web, reaching more and more targets.

□ Damages:

- ▣ Browser hijacking – URL injection attacks can implant malware that takes control of your browser, spreading malware across the web and monitoring your activity. Browser hijackers are usually intended to maximize the attacker's ad revenues but can also lead to spyware or costly ransomware attacks.
- ▣ Data loss – This is the most common outcome of phishing websites. Many fraudulent websites seek to siphon confidential information via forms and sham payment systems. Successful phishing attacks cost companies an average of \$14.8 million per year, making it a security and financial concern.

How to secure users from malicious websites

- Fortunately, there are several things web users can do to limit the risks posed by malicious websites. For instance, these measures should serve as a baseline when managing risks:
 - ▣ Patch your operating system and apps regularly (including web browsers). Many attacks leverage zero-day exploits that updates will negate.
 - ▣ Employ reputable anti-virus software and filtering tools. Every device on a network should have fully-updated antivirus and specialist anti-malware tools that can detect drive-by infections as soon as they appear.
 - ▣ Avoid opening unsolicited attachments in phishing emails and take care when following links in the email text. Verizon's 2020 Data Breach Investigations Report found that 96% of phishing attacks occur via email. Because of this, email security is a crucial training area for corporate security teams.

□ Continued..

- ▣ If you land on dangerous sites, use the detection measures listed above to assess whether it is legitimate. Do not open any unwanted downloads or accept notifications unless you are sure the site is safe.
- ▣ You can generally check web URLs to ensure they are what they claim to be. And if you have any concerns about site security, ask the website owner about their identity and security practices.
- ▣ Segmenting networks can also be a wise move. Ensure employees can access core work resources while separating those resources from the wider web.
- ▣ Train staff in device security, credentials management, identifying phishing emails, and general web safety. Create clear protocols regarding acceptable behavior, and employ user activity monitoring systems to ensure staff avoids risky websites.

JavaScript Analysis

□ What is JavaScript?

- ▣ JavaScript is a core web programming language used by 93.6% of websites
- ▣ Different from Java - they are separate programming languages
- ▣ Allows websites to be interactive and dynamic
- ▣ Files end in .js extension
- ▣ Question: **Why do you think JavaScript is so widely used on the web?**

Why Criminals Use JavaScript

- ❑ **Widespread usage** makes it an attractive target
- ❑ **Easy to hide** malicious redirects
- ❑ Can **reach** millions of users **quickly**
- ❑ Low cost for attackers
- ❑ Difficult to detect
- ❑ Question: What motivates cybercriminals to target JavaScript?

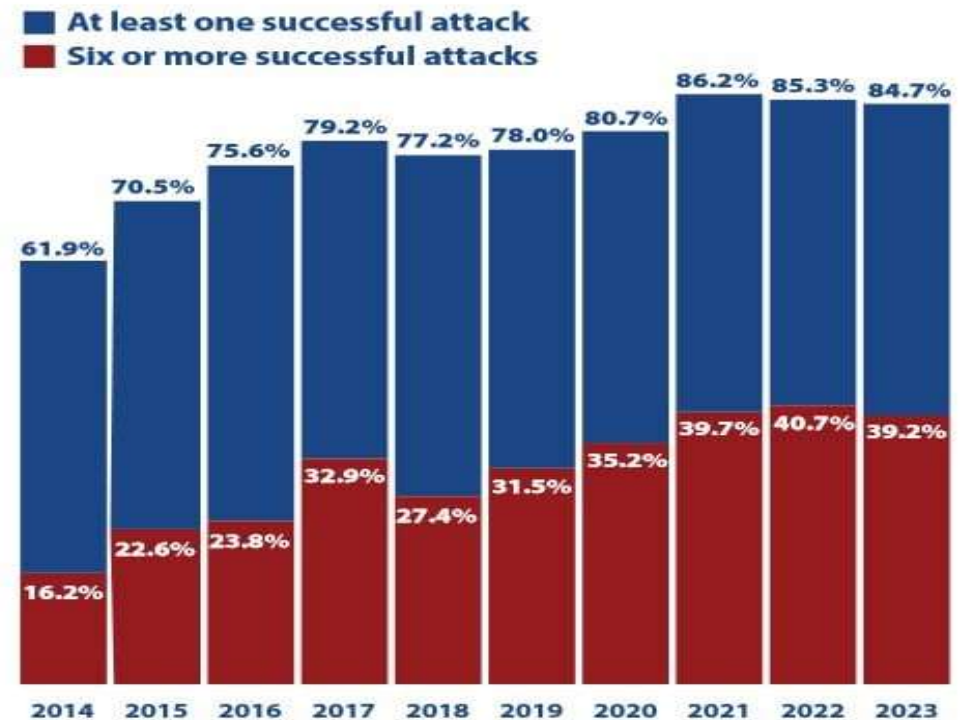
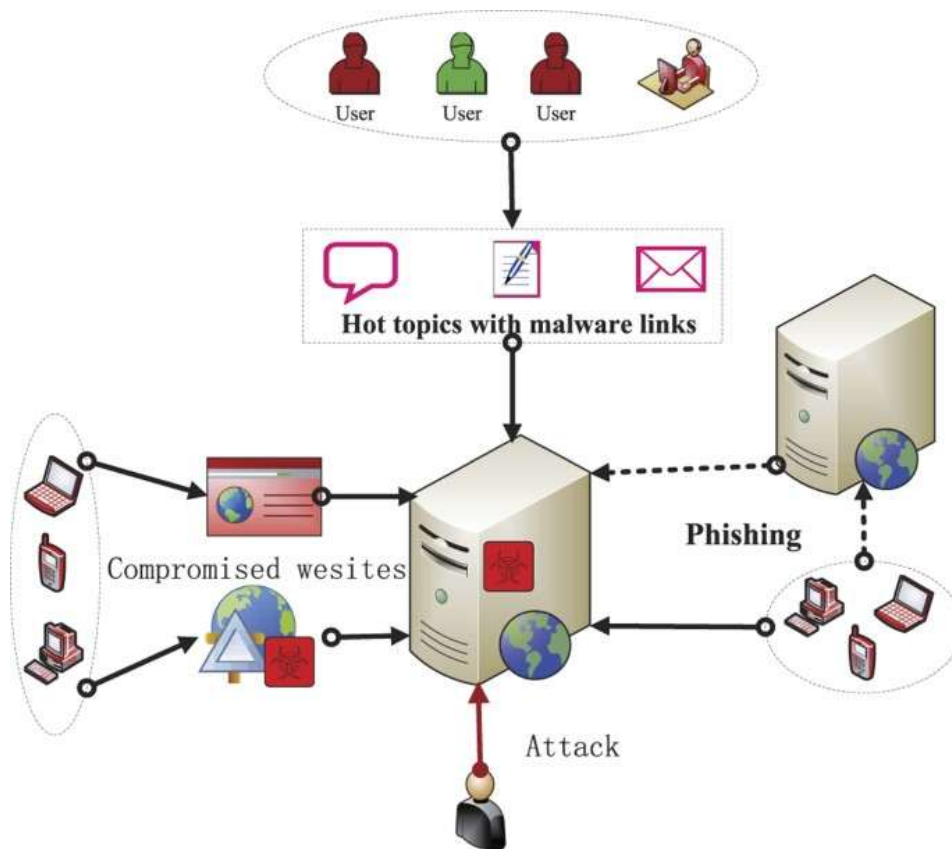


Figure 1: Percentages compromised by at least one successful attack and by six or more successful attacks.

How JavaScript Malware Works



- ❑ Malicious code is injected into legitimate websites
- ❑ When users visit infected sites, malware downloads automatically
- ❑ No user interaction needed - called "drive-by downloads"
- ❑ Process happens silently in background
- ❑ Question: **What makes this type of attack particularly dangerous?**

Typical red flags include

- ❑ heavy obfuscation
- ❑ long unreadable variable names or meaningless random names
- ❑ use of `eval()`, `Function()`, `setTimeout()` or `setInterval()` with encoded strings
- ❑ Base64 decoding such as `atob()`
- ❑ string splitting, reversing, concatenation, or XOR-style decoding
- ❑ suspicious DOM (Document Object Model) manipulation
- ❑ redirection to external URLs
- ❑ cookie theft, form capture, or session token access
- ❑ dynamically creating `<script>` tags or iframes
- ❑ calls to browser storage, clipboard, or credential-related data

Continued

- ❑ Malicious JavaScript code injections in legitimate websites – used to redirect users to malware-laden websites or to exploit servers that trigger malware infections.
- ❑ Hidden iFrames – that load JavaScript malware from compromised sites, malware which then tries to execute code in the browser to infect the PC.
- ❑ Malicious JavaScript code injections in online advertising networks – which appears in online banner ads and also silently redirect users to malicious web locations.
- ❑ Drive-by downloads – which use infected JavaScript files to launch malware infections.
- ❑ Malicious JavaScript attachments – which are ran through a Windows program and can trigger insidious infections outside the browser.
- ❑ Infected downloads triggered through compromised JavaScript code injects – such as fake antivirus products, which are one of the most common scams on the Internet. These can compromise your system beyond the point of no return.
- ❑ Browser add-ons and plugins – these can be either infected or they can load external content loaded with malware from external sources.
- ❑ Fake software pop-up messages – that cyber crooks can easily forge to look real and convincing.

Basic analysis approach

1. Identify the entry point

- Check where the script comes from:
 - ▣ inline script in HTML
 - ▣ external .js file
 - ▣ injected third-party script
 - ▣ malicious ad or compromised CDN/library
 - ▣ phishing page script
 - ▣ script embedded in PDF, email attachment, or HTML file

2. Perform static analysis

- Read the code without executing it.
- Focus on: suspicious functions:
 - ▣ eval, document.write, innerHTML, fetch, XMLHttpRequest, WebSocket
 - ▣ encoded payloads
 - ▣ hidden URLs/domains
 - ▣ credential or form harvesting logic
 - ▣ environment checks such as browser, OS, devtools detection
 - ▣ staged loaders that download another script

Continued..

3. Perform dynamic analysis

- ▣ Run it only in a safe, isolated environment:
 - ▣ VM or sandbox
 - ▣ isolated browser profile
 - ▣ no personal accounts logged in
 - ▣ restricted network or monitored proxy
 - ▣ snapshots enabled
- ▣ Dynamic analysis helps confirm:
 - ▣ what URLs are contacted
 - ▣ whether files are dropped or downloaded
 - ▣ whether cookies, keystrokes, or form data are stolen
 - ▣ whether redirections or fake login overlays appear

4. Map behavior to attack goals Ask:

- ▣ Is it stealing credentials?
 - ▣ Is it redirecting victims?
 - ▣ Is it exploiting the browser?
 - ▣ Is it acting as a downloader?
 - ▣ Is it injecting ads or crypto-mining code?
 - ▣ Is it persisting through service workers/local storage/browser extensions?

Common malicious JavaScript techniques

□ **Obfuscation**

- ▣ Attackers hide intent using packing, minification abuse, string arrays, unicode tricks, or layered decoding.

□ **Injection / XSS**

- ▣ OWASP describes reflected, stored, and DOM-based XSS as ways malicious JavaScript gets executed inside a victim's browser.

□ **Drive-by activity**

- ▣ A compromised or malicious site can attempt code execution or exploitation just from a visit, which MITRE classifies as Drive-by Compromise.

□ **Malvertising / fake installers**

- ▣ Microsoft has documented campaigns where users are lured through malicious ads and fraudulent sites into downloading Node.js-based or JavaScript-related payloads.

Types of JavaScript Malware

- ❑ Ransomware (like Ransom32 and RAA)
- ❑ Financial malware
- ❑ Botnet malware
- ❑ Data stealing malware
- ❑ Question: Why would criminals create different types of malware?

Key Protection Methods



Over all system protection

- Keep all software updated
- Use strong antivirus
- Install traffic filtering
- Avoid suspicious links
- Don't open spam attachments
- Stay away from suspicious websites



Browser Security Settings

- Chrome: Adjust JavaScript settings in Privacy
- Firefox: Use NoScript extension
- Create trusted website exceptions
- Balance security vs functionality
- Question: What factors should you consider when adjusting these settings?

Moral of the story:

- ▣ Use multiple security layers
- ▣ Keep software updated
- ▣ Monitor system regularly
- ▣ Stay educated about threats
- ▣ Use security best practices
- ▣ Question: Why is a multi-layered approach important?

PDF Files and Security Risks

- Portable Document Format created by Adobe in 1993
- Cross-platform file format supporting text, images, links, and more
- Maintains consistent appearance across different devices and software
- Question: Why do you think PDFs became so widely used in business?



PDF File Structure

- Header: Contains PDF version information
- The body : The document's part that holds all of the information including text and other elements such as images, links, etc.
 - ▣ The body of the PDF file contains different objects which can reference each other, the objects have different types:
 - ▣ Names – /name backslash followed by ASCII characters – setting a unique name.
 - ▣ Strings – (text) its full syntax is a bit complex but what's important is to know that it is enclosed in parentheses.
 - ▣ Arrays – enclosed with square brackets ([...]) can contain other objects.
 - ▣ Dictionaries – table of key and value pairs. The key is a name object and the value can be any other object. Enclosed within double angle brackets (<<...>>)
 - ▣ Streams – contains embedded data structures like images (or code) which can be compressed. Streams represented by a dictionary that set the stream's length with the key /Length and encoding /Filters.
 - ▣ Indirect object – object that has a unique ID, the object starts with the keyword obj and ends with endobj other objects can reference the object using its ID. For example a reference to object with ID 3 we would look like this: 3 0 R

- Cross-reference table – Specifies the offset from the start of the file to each object in the file, so that the PDF reader will be able to locate them without loading the whole document (it can save time when opening big files).
- Trailer – Specifies information about the cross-reference table so the PDF reader will be able to find the table and other objects.

Security Risks with PDFs

- Most common malicious file type in phishing emails
- Can contain hidden malicious code
- Supports potentially dangerous JavaScript
- May exploit PDF reader vulnerabilities
- Question: What makes PDFs attractive to cybercriminals?

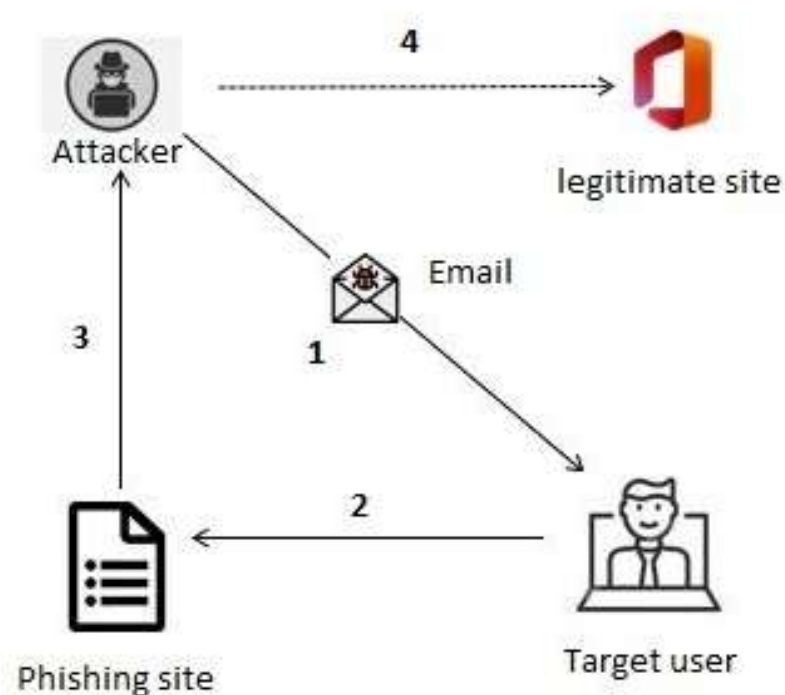
Common PDF Attack Methods

- ❑ Malicious links disguised as buttons or images
- ❑ Embedded JavaScript code execution
- ❑ Compressed malicious content in streams
- ❑ Exploitation of PDF reader vulnerabilities
- ❑ Question: How can users protect themselves from these attacks?

Signs of Malicious PDFs

- ❑ Presence of JavaScript code
- ❑ Embedded executable files
- ❑ Multiple encoded streams
- ❑ External links to suspicious domains
- ❑ Question: What would make you suspicious of a PDF file?
- ❑ Analysis Tools
 - ▣ peepdf: Python tool for parsing and analyzing PDFs
 - ▣ pdf-parser: Extracts and inspects PDF objects
 - ▣ Automated analysis platforms like Intezer
 - ▣ File inspection tools for embedded content

Real Attack Example



- PDF appears as Amazon login request
- Contains hidden malicious JavaScript
- Redirects to fake login page
- Steals user credentials
- Question: How could you identify this as a scam?

Protection Strategies

- ❑ Keep PDF readers updated
- ❑ Be cautious of unexpected PDF attachments
- ❑ Don't click links in untrusted PDFs
- ❑ Use security scanning tools
- ❑ Question: What other security practices would you recommend?

Moral of the story:

PDFs are versatile but can be dangerous

- ❑ Multiple attack vectors are possible
- ❑ Always verify source and authenticity
- ❑ Use security tools and best practices
- ❑ Question: How will this knowledge change your PDF handling?

RTF Exploit (Understanding CVE-2017-0199: Anatomy of an RTF Exploit)

- CVE-2017-0199 is a security vulnerability discovered in 2017
- Microsoft released a patch on April 11, 2017
- The exploit targets RTF (Rich Text Format) documents
- Why do you think attackers often use document files for exploits?